CISPA
HELMHOLTZ CENTER FOR
INFORMATION SECURITY

Cryptography

Chapter 10: Real World Parameters

Julian Loss

From Theory to Practice

- You've seen several (public key) crypto schemes
- Security proof usually via reduction to some hardness assumption
- How would you pick parameter sizes for these schemes?
- Conventional Wisdom:
  - 256 bit elliptic curve gives 128 bit security
  - 4096 bit RSA gives 128 bit security
- Why? What does this mean? Is it actually true?

When Asymptotics Fail

- So far, we've made **asymptotic statements**
- **Example:** If every PPT algorithm has negligible advantage in solving CDH in $\mathbb{G}$, then BLS is secure over $\mathbb{G}$
- **Problem:** Asymptotic definitions do not make sense once we pick a **concrete** $\mathbb{G}$
- What does negligible and PPT actually mean?

Defining Security, Concretely

- **Expected running time (for brute-force attack):**
  - Suppose that $\mathscr{A}$ breaks signature scheme Sig in t steps with probability ϵ.
  - Then $\mathscr{A}$ breaks Sig after $T = t/\epsilon$ steps **in expectation**
- **Alternative approach:** If every algorithm has **expected running time** $T \geq 2^{\kappa}$ in breaking the security of Sig , then Sig has κ bits of security
- How do we calculate the expected running time?

Defining Security, Concretely (for BLS)

- **Alternative approach (for BLS):** If every algorithm has **expected running time** $T \geq 2^{\kappa}$ in breaking BLS over $\mathbb{G}$, then BLS has κ bits of security
- We can use **concrete hardness estimations** for CDH over $\mathbb{G}$, if $\mathbb{G}$ is an elliptic curve group
- **Theorem (Shoup)**: The probability of solving CDH over a prime order elliptic curve group of size p in time t is $O(t^2/p)$.
- Setting $t_{CDH} = 2^{\kappa}$, we obtain $\dfrac{t_{CDH}}{\epsilon_{CDH}} \geq \dfrac{t_{CDH}}{t_{CDH}^2/p} = \dfrac{p}{t_{CDH}} \implies p = 2^{2\kappa}$

Defining Security, Concretely (for BLS)

- **Alternative approach (for BLS):** If every algorithm has **expected running time** $T \geq 2^{\kappa}$ in breaking BLS over $\mathbb{G}$, then BLS has κ bits of security
- **Theorem 10.1 (concretely):** If $\mathscr{A}$ breaks BLS in time $t_{\mathscr{A}}$ with probability $\epsilon_{\mathscr{A}}$, then there is an algorithm $\mathscr{B}$ that runs in time $t_{\mathscr{B}} = t_{\mathscr{A}}$ and breaks CDH with probability $\epsilon_{\mathscr{B}} \geq \dfrac{\epsilon_{\mathscr{A}}}{q_h}$
- Rearranging terms: $\dfrac{q_H t_{\mathscr{A}}}{\epsilon_{\mathscr{A}}} \geq \dfrac{t_{\mathscr{B}}}{\epsilon_B} \geq 2^{\kappa}$ (second inequality comes from previous slide)
- If $\kappa = 128$, $q_H = 2^{80}$, then $\dfrac{t_{\mathscr{A}}}{\epsilon_{\mathscr{A}}} \geq \dfrac{2^{\kappa}}{q_H} \geq 2^{48} \Longrightarrow$ Only 48 bits of security left!
- Must compensate by making $p \approx 2^{340}$; signatures grow by about $30\,\%$!

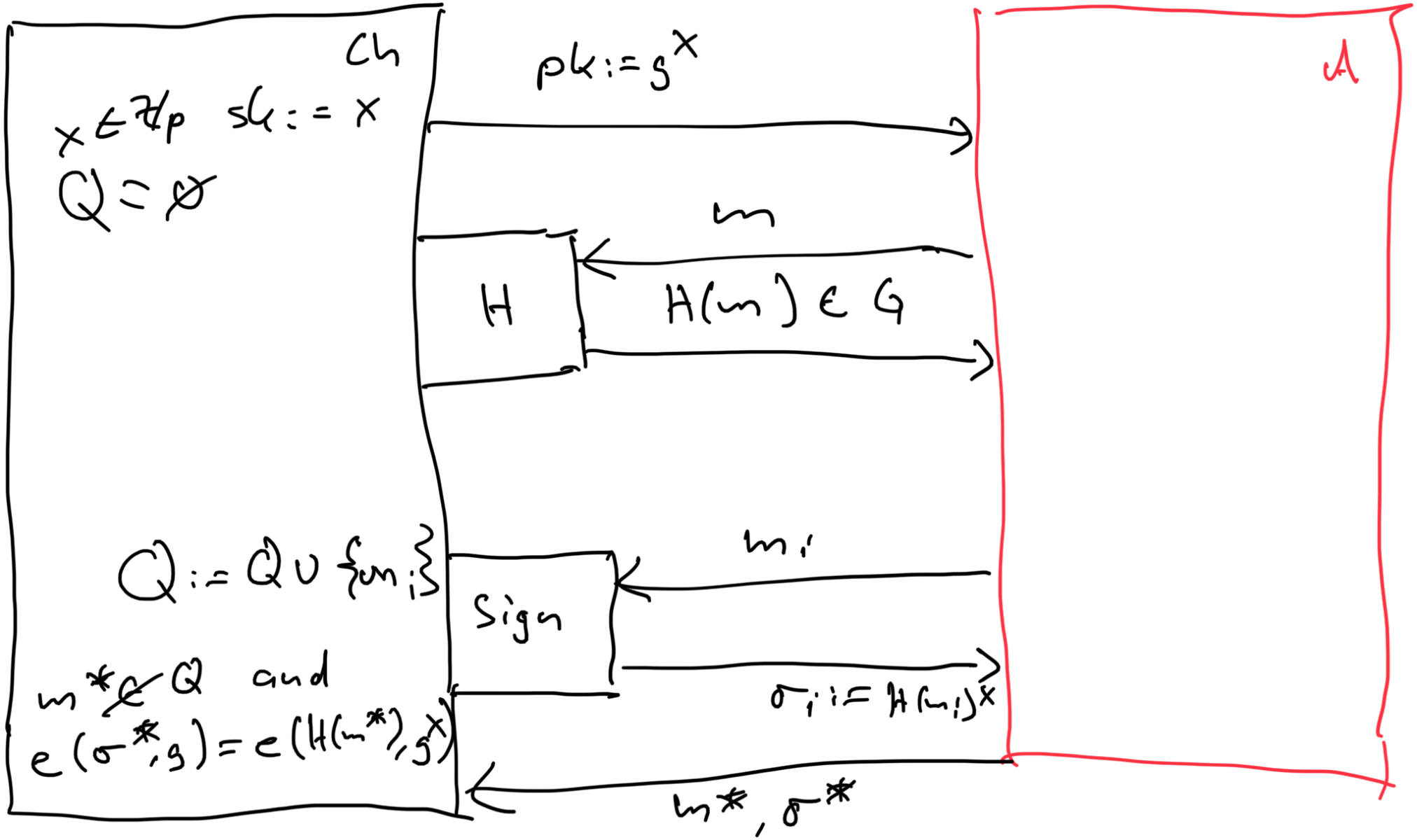
Tightness Matters

- We call a reduction **tight** if $\frac{t_{\mathscr{A}}}{\epsilon_{\mathscr{A}}} \approx \frac{t_{\mathscr{B}}}{\epsilon_{\mathscr{B}}}$
- Otherwise, the reduction is **loose**
- Tighter reduction $\Longrightarrow$ better parameters
- Can we improve the parameters for BLS?

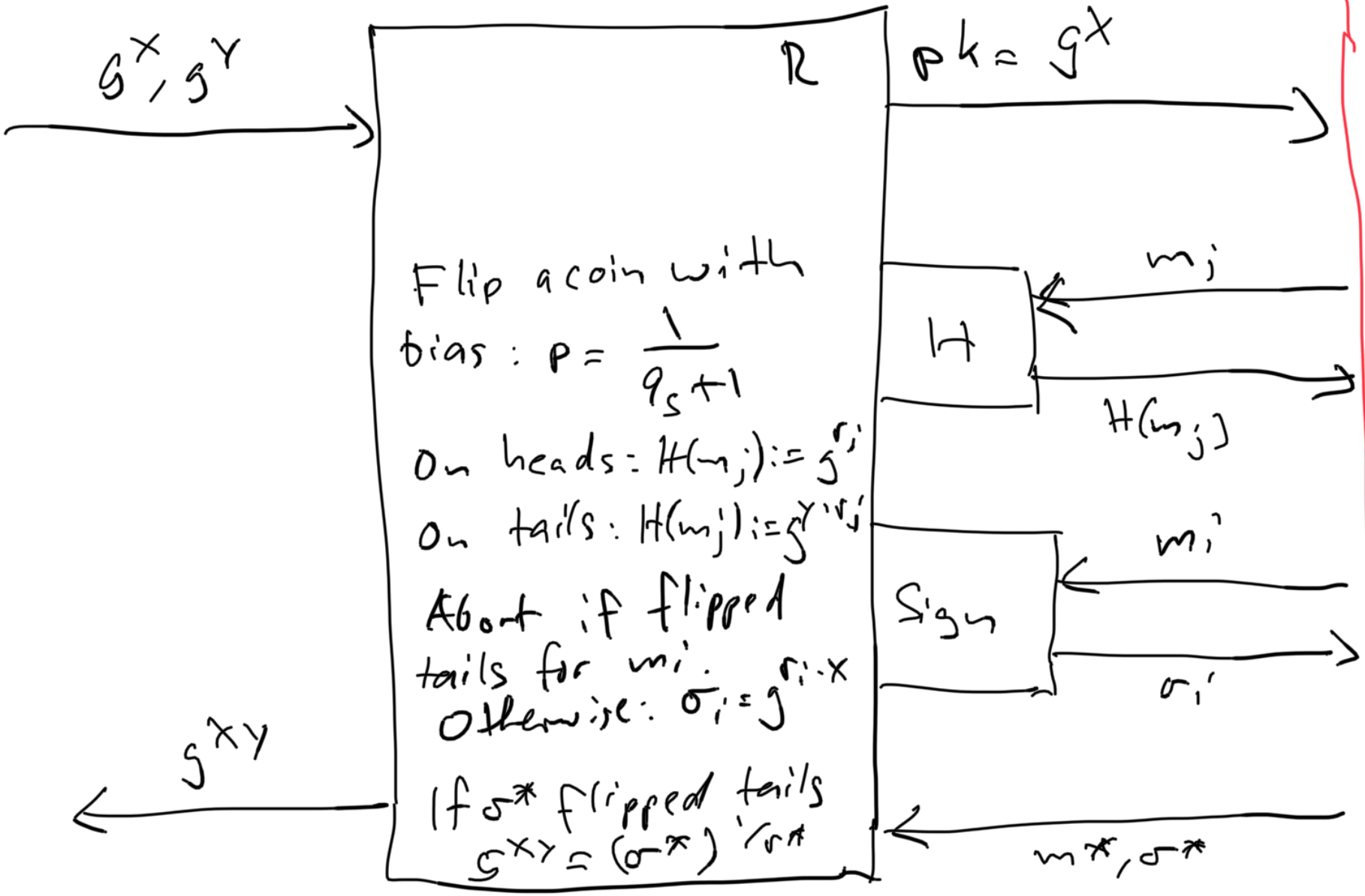
Theorem 10.2

- Let $\mathbb{G}$ be a group of prime order p. For every adversary $\mathscr{A}$ that runs in time at most $t_{\mathscr{A}}$, makes at most q_s signing queries, and breaks the security of BLS (instantiated over $\mathbb{G}$) with probability at least $\epsilon_{\mathscr{A}}$, there exists an adversary $\mathscr{B}$ that runs in time at most $t_{\mathscr{B}} = t_{\mathscr{A}}$ and breaks the CDH assumption over $\mathbb{G}$ with probability at least $\epsilon_{\mathscr{B}} \geq \dfrac{\epsilon_{\mathscr{A}}}{q_s}$
- **Note:** In practice, $q_s \ll q_h$, i.e., $q_s \approx 2^{30}$, whereas $q_h \approx 2^{80}$

Proof


Ch
$x \in \mathbb{Z}_p$ $sk := x$
$Q = \emptyset$
$pk := g^x$
$\mathcal{A}$
m
H
$H(m) \in G$
$Q := Q \cup \{m_i\}$
m_i
Sign
$\sigma_i := H(m_i)^x$
$m^* \notin Q$ and
$e(\sigma^*, g) = e(H(m^*), g^x)$
m^*, σ^*

Proof


g^x, g^y
R
$pk = g^x$
Flip a coin with bias: $p = \frac{1}{q_s+1}$
On heads: $H(m_j) := g^{r_j}$
On tails: $H(m_j) := g^{y \cdot r_j}$
Abort if flipped tails for m_i.
Otherwise: $\sigma_i = g^{r_i \cdot x}$
If σ^* flipped tails $g^{xy} = (\sigma^*)^{1/r^*}$
g^{xy}
H
m_j
$H(m_j)$
Sign
m_i
σ_i
m^*, σ^*

Proof

E_1^i: R does not abort in signing query i

E_2: m^* corresponds to tails

$$\Pr\left[\bigwedge_{i=1}^{q_s} E_1^i \wedge E_2\right] = \Pr\left[\bigwedge_{i=1}^{q_s} E_1^i\right] \cdot \Pr[E_2]$$

$$= \frac{1}{(q_s+1)} \cdot \prod_{i=1}^{q_s} \Pr[E_1^i] = \frac{1}{(q_s+1)} \prod_{i=1}^{q_s} \left(1 - \frac{1}{q_s+1}\right)$$

$$= \frac{1}{(q_s+1)} \cdot \left(1 - \frac{1}{q_s+1}\right)^{q_s} \geq \frac{1}{(q_s+1)} \cdot \frac{1}{e}$$

$\Rightarrow$ Overall success probability of R: $\dfrac{\varepsilon_{BLS}}{e \cdot (q_s+1)}$

The Katz-Wang Trick

- A theorem by Coron shows that a loss of q_s is the optimal tightness for BLS
- Proof relies heavily on the fact that BLS has **unique** signatures (only a single signature per message and public key is possible)
- What if we make BLS non-unique?

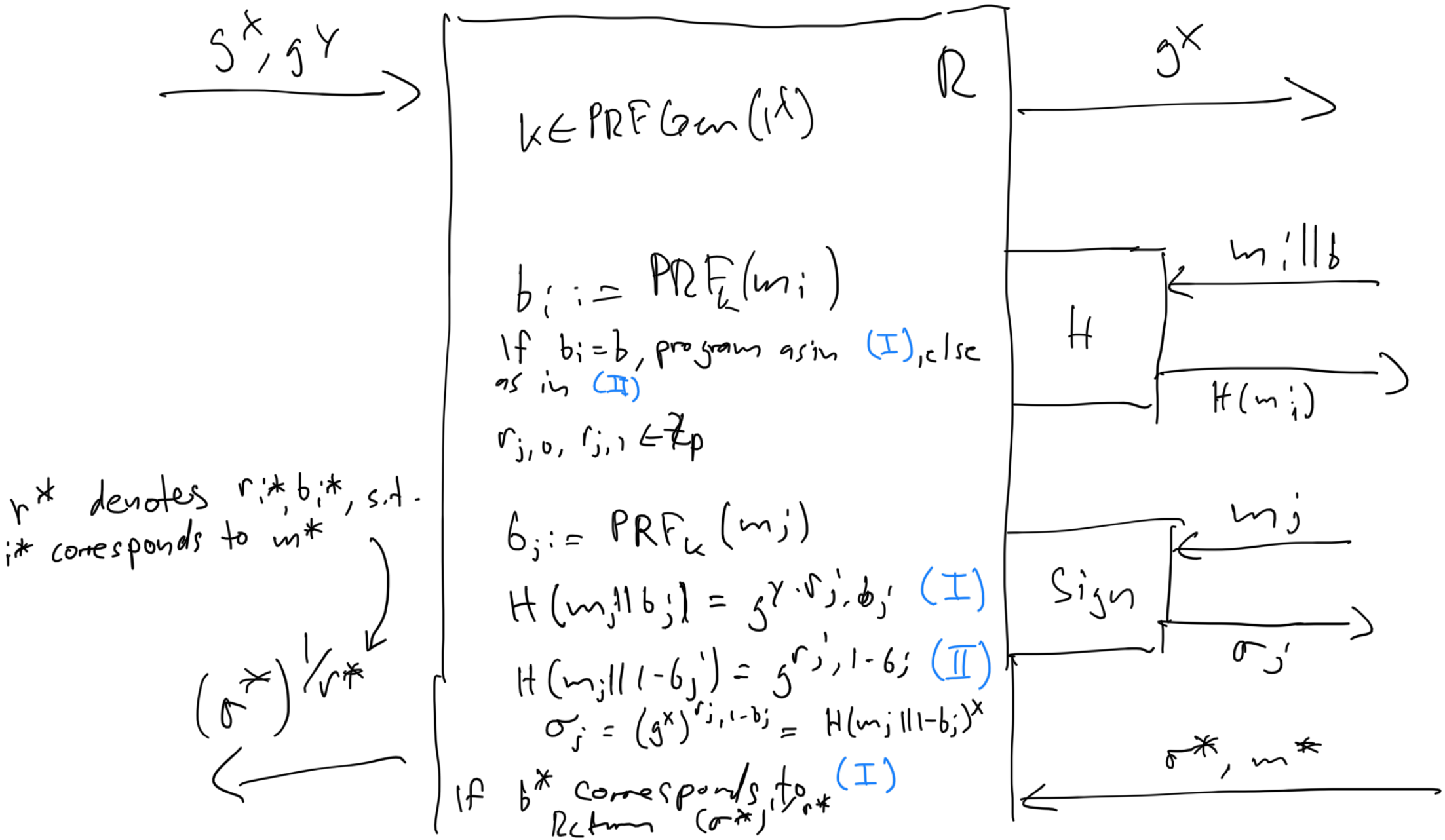
The Katz-Wang Trick

- Katz and Wang: BLS has a **tight** reduction if we append **a single bit**
- Let $PRF_k : \{0,1\}^* \longrightarrow \{0,1\}$ be a PRF
- The modified BLS scheme $(Gen, Sign, Verify)$ is given as follows
  - $Gen(1^\lambda)$: Sample $x \leftarrow \mathbb{Z}_p$ and a PRF key k. Output $vk \leftarrow g^x$ and $sk \leftarrow (x, k)$
  - $Sign(x, m)$: Compute and output $\sigma \leftarrow H(m||PRF_k(m))^x \in \mathbb{G}$
  - $Verify(vk = g^x, m, \sigma)$: If $e(H(m||b), g^x) = e(g, \sigma)$ for some $b \in \{0,1\}$, output 1, otherwise 0

Theorem 10.3

- Let $\mathbb{G}$ be a group of prime order p. For every adversary $\mathscr{A}$ that runs in time at most $t_{\mathscr{A}}$ and breaks the security of the modified BLS scheme (instantiated over $\mathbb{G}$) with probability at least $\epsilon_{\mathscr{A}}$, there exists an adversary $\mathscr{B}$ that runs in time at most $t_{\mathscr{B}} = t_{\mathscr{A}}$ and breaks the CDH assumption over $\mathbb{G}$ with probability at least $\epsilon_{\mathscr{B}} \geq \frac{\epsilon_{\mathscr{A}}}{2}$.

Proof


g^x, g^y
R
$k \leftarrow PRFGen(1^\lambda)$
$b_i := PRF_k(m_i)$
If $b_i = b$, program as in (I), else as in (II)
$r_{j,0}, r_{j,1} \leftarrow \mathbb{Z}_p$
$b_j := PRF_k(m_j)$
$H(m_j \| b_j) = g^{y \cdot r_{j,b_j}}$ (I)
$H(m_j \| 1-b_j) = g^{r_{j,1-b_j}}$ (II)
$\sigma_j = (g^x)^{r_{j,1-b_j}} = H(m_j \| 1-b_j)^x$
If b^* corresponds to r^* (I)
Return $(\sigma^*)^{1/r^*}$
g^x
H
$m_i \| b$
$H(m_i)$
Sign
m_j
σ_j
σ^*, m^*
r^* denotes r_{i^*}, b_{i^*}, s.t. i^* corresponds to m^*

Proof

Proof